COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.1 · Security Procedures

Mestre CyberSec · **Lesson 5.1 — Security Procedures** (7:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Procedure: operacional — onboarding (criar conta/acesso), offboarding (Desativar, revogar, coletar equipamento — o esquecido gera ORPHAN account); resposta a phishing; reset de senha.

💡 Key Exam Highlights & Critical Concepts

- Offboarding: desativa conta, revoga acesso — o esquecido gera ORPHAN
- Orphan account = conta sem dono após offboarding falho — risco alto

🎯 Exam Tips & Typical CompTIA Scenarios

- 'process when employee leaves the company'=offboarding

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.1 — Security Procedures)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Onboarding (N/A)

The operational procedure for granting a new employee the accounts, access, and equipment required for their role, following least privilege.

⚠ ***Exam Trap:*** *Prova: 'new employee access' ou 'criar conta/acesso' = onboarding. Não confunda com offboarding.*

• Offboarding (N/A)

The operational procedure for disabling accounts, revoking access, and collecting equipment when an employee leaves; failure creates orphan accounts.

⚠ ***Exam Trap:*** *Gatilho clássico: 'process when employee leaves the company' = offboarding. Inclui desativar/revogar/coletar, não apenas deletar conta.*

• Orphan Account (N/A)

An active account left without an owner after failed offboarding or missed account removal, creating unauthorized access risk.

⚠ ***Exam Trap:*** *Palavra-chave: conta esquecida após desligamento = orphan account. É risco alto; deve ser desativada/removida imediatamente.*

• Account Provisioning (N/A)

The process of creating, managing, and assigning user accounts and permissions, typically during onboarding and role changes.

⚠ ***Exam Trap:*** *Diferença: provisioning concede acesso; deprovisioning/offboarding remove. Onboarding normalmente usa provisioning com menor privilégio.*

• Access Revocation (N/A)

The act of removing or disabling a user's permissions, tokens, and sessions so they can no longer access resources after offboarding or role change.

⚠ ***Exam Trap:*** *Prova: offboarding exige revogar acesso, não só desativar conta; sessões ativas e credenciais também devem ser invalidadas.*

• Phishing Response (N/A)

The documented procedure for reporting, containing, and analyzing suspected phishing messages to prevent credential theft and malware spread.

⚠️ ***Exam Trap:*** *Gatilho: usuário recebe e-mail suspeito; a primeira ação segura é reportar ao time de segurança, não clicar, responder ou abrir anexo.*

• Password Reset (N/A)

A security procedure for verifying identity and allowing a user to set a new password after a forgotten or compromised credential.

⚠️ ***Exam Trap:*** *Prova: reset de senha exige verificação de identidade; não envie senha por e-mail. MFA e perguntas de segurança podem ser usados na verificação.*

• Standard Operating Procedure (SOP)

A documented, repeatable set of steps for routine security operations such as onboarding, offboarding, phishing response, and password resets.

⚠️ ***Exam Trap:*** *Conceito guarda-chuva: procedimentos operacionais de segurança devem ser documentados, seguidos e revisados; não são opcionais.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Standard Operating Procedures (SOPs)

🏠 **Real-World Analogy:** The commercial airline pilot pre-flight checklist or a Michelin-star recipe card. It leaves zero ambiguity: 'Step 1: Check fuel pressure valve; Step 2: Engage green hydraulic switch; Step 3: If gauge indicates normal, proceed to radio tower'. Any trained crew executes the task with reproducible precision.

🔍 **Root Cause & Background:** Under time pressure or during routine tasks, administrators rely on memory and skip critical verification steps such as pre-patch backups, hash validation, or firewall closure.

🛡️ **GRC Auditor Perspective:** Verify documented SOP existence for core tasks, validate that junior staff can execute them unambiguously without external help, and ensure post-incident lessons learned trigger SOP updates.

⚠️ **How CompTIA Tests This:** Exam trigger: 'step-by-step instructions on how to accomplish a specific operational security task' = Procedure / SOP.

📌 Onboarding & Access Provisioning Procedures

🏠 **Real-World Analogy:** Hotel guest check-in: the front desk verifies government photo ID, matches payment records, and issues a programmed keycard granting entry strictly to the rented room and fitness center, while deadlocking staff pantries and the manager's safe.

🔍 **Root Cause & Background:** The rush to get new personnel productive leads helpdesk staff to clone legacy user profiles or assign blanket local administrator rights by default.

🛡️ **GRC Auditor Perspective:** Audit the HR-to-IT provisioning pipeline: ensure creation requests have formal business owner sign-off, adhere strictly to Least Privilege, and utilize automated SCIM/identity lifecycle tooling.

⚠️ **How CompTIA Tests This:** Exam trigger: 'ensuring new hires receive appropriate role-based permissions based on least privilege and signed agreements before access is granted' = Onboarding Procedure.

📌 Offboarding & Account Deprovisioning Procedures

🏠 **Real-World Analogy:** The departure protocol for a bank employee holding master vault combinations: the moment termination occurs, physical keycards are confiscated, vault combinations are rotated, alarm codes are cancelled, company vehicle keys returned, and security escorts them to the exit.

🔍 **Root Cause & Background:** Communication gaps between Human Resources and IT departments leave departing user accounts active for months (orphan accounts), enabling revenge saboteurs or quiet IP theft.

🛡️ **GRC Auditor Perspective:** Reconcile the last 12 months of official HR termination rosters against live Active Directory/IdP directory listings to flag unrevoked orphan accounts, and verify hardware asset return receipts.

⚠️ **How CompTIA Tests This:** Exam trigger: 'prevent orphan accounts and unauthorized access by recently separated employees' = Immediate Offboarding / Account Deprovisioning Procedure.

📌 Phishing Escalation & Secure Password Reset Procedures

🏠 **Real-World Analogy:** A public notary issuing official property deed reissues: the officer refuses to trust a random phone caller claiming 'I forgot my password, please reset it'. They enforce independent out-of-band verification (calling back the HR record phone number or in-person biometric validation).

🔍 **Root Cause & Background:** Social engineering phone exploits (vishing) where attackers pose as frantic C-level executives pleading with Tier 1 helpdesk staff for immediate emergency password resets.

🛡️ **GRC Auditor Perspective:** Conduct mystery-caller vishing audits against Helpdesk support, audit mandatory out-of-band identity proofing mechanisms prior to resets, and inspect SOC triage tickets for phishing reports.

⚠️ **How CompTIA Tests This:** Exam trigger: 'help desk must verify employee identity via manager callback or out-of-band verification before resetting credentials' = Secure Password Reset Procedure.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Detailed step-by-step documentation guiding an analyst through revoking expired digital certificates	**Standard Operating Procedure (SOP)**
New hire is provisioned in the directory with minimum access strictly limited to required job folders	**Onboarding Procedure**
Auditor discovers active Active Directory credentials belonging to employees terminated three months prior	**Offboarding Failure / Orphan Accounts**
User receives a phishing email and hits the report button, escalating the raw message headers directly to the SOC	**Phishing Escalation Procedure**
Support technician demands a video callback and manager verification before resetting a VIP corporate account	**Identity Proofing Procedure**
Security team reviews and updates the ransomware response checklist immediately after containing a major breach	**Post-Incident SOP Refinement**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hiring manager verbally asks the service desk to create an account for a new employee and grant access to the finance shared drive. HR has not yet completed the onboarding record, and the service desk has no written approval from the system owner. Which action best follows the onboarding procedure?

A) Create the account immediately and grant finance access because the manager approved it verbally to comply with mandatory regulatory governance standards

B) Create the account under a temporary shared finance account until HR completes the record within established organizational risk appetite thresholds

C) Create the account with standard default access only, and add finance access after a formal authorized request is approved.

D) Create the account and email the initial password to the employee's personal address in accordance with documented business impact analysis criteria

QUESTION 2 · EXAM SCENARIO

A security team receives notice that an employee is terminated effective immediately. The employee has an active VPN account, email account, and cloud application tokens. According to the offboarding procedure, which action should be performed first?

A) Disable the account and revoke active sessions and tokens.

B) Delete the account and all associated data immediately to ensure third-party supplier accountability and oversight

C) Reset the password and wait for the manager to confirm the termination.

D) Transfer the mailbox to the manager before disabling the account.

QUESTION 3 · EXAM SCENARIO

During a quarterly access review, an auditor finds an active domain account that belongs to a contractor who left the company six months ago. No manager owns the account, and it is still enabled. Which term describes this account?

A) Service account

B) Orphan account

C) Shared account

D) Privileged account

QUESTION 4 · EXAM SCENARIO

A user receives an email claiming that their password will expire and urging them to click a link to reset it. The user reports the email to the service desk without clicking the link. According to the phishing response procedure, what should the service desk do first?

A) Forward the email to all employees so they can watch for similar messages in accordance with documented business impact analysis criteria

B) Tell the user to delete the email and continue working normally to satisfy external independent certification audit controls

C) Reset the user's password immediately and close the ticket while preserving chain of custody and forensic integrity

D) Instruct the user not to interact with the message, preserve the email, and escalate it to the security team.

QUESTION 5 · EXAM SCENARIO

A help desk agent receives a call from someone requesting a password reset. The caller knows the username and manager name but cannot provide the employee ID or answer the approved verification questions. What should the agent do according to the password reset procedure?

A) Follow the approved identity verification process; if verification fails, do not reset and escalate the request.

B) Reset the password to a temporary value and send it to the caller's personal email while preserving chain of custody and forensic integrity

C) Ask the caller for the current password to verify identity under formally agreed service level and operating agreements

D) Disable MFA for the account so the caller can use self-service reset to demonstrate legally defensible due diligence and due care

QUESTION 6 · EXAM SCENARIO

An employee's account was disabled on their last day, but the corporate laptop was never returned. Which additional offboarding control best mitigates the risk of data exposure from the missing device?

A) Change all domain passwords across the organization while preserving chain of custody and forensic integrity

B) Delete the former employee's email mailbox under formally agreed service level and operating agreements

C) Remotely wipe the laptop and track asset return through the offboarding checklist.

D) Disable the former employee's MFA token in compliance with statutory privacy and data protection mandates

QUESTION 7 · EXAM SCENARIO

A security analyst confirms that a reported email contains a malicious link and was delivered to multiple employee mailboxes. Which action best follows the phishing containment procedure?

A) Send an organization-wide warning to all employees about the message.

B) Reset passwords for every employee who received the email to demonstrate legally defensible due diligence and due care

C) Ask recipients to forward the email to the security team for tracking.

D) Quarantine the message from all mailboxes and block the sender and URL.

QUESTION 8 · EXAM SCENARIO

A manager requests domain administrator access for a new marketing employee 'for future projects.' The onboarding procedure requires role-based provisioning and least privilege. What should the security administrator do?

A) Grant domain administrator access temporarily and review it after 90 days to demonstrate legally defensible due diligence and due care

B) Deny the request and provision only the standard marketing role access; require separate justification and approval for any privileged access.

C) Grant domain administrator access but require MFA for the account to provide defensible quantitative risk metrics for leadership

D) Create the account under an existing marketing shared administrator credential to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

A user reports an unauthorized VPN login from another country while the account is still active. Which action best follows the account compromise procedure?

A) Disable the account and revoke active sessions and tokens, then reset credentials.

B) Reset the password only after the user returns to the office to provide defensible quantitative risk metrics for leadership

C) Increase password complexity requirements and continue monitoring to comply with mandatory regulatory governance standards

D) Delete the user's email mailbox and VPN profile within established organizational risk appetite thresholds

QUESTION 10 · EXAM SCENARIO

An organization repeatedly discovers orphan accounts because HR notifications about departing employees are delayed. Which control in the offboarding standard operating procedure best prevents this problem?

A) Require annual security awareness training for all employees to provide defensible quantitative risk metrics for leadership

B) Enforce quarterly password expiration for all user accounts to comply with mandatory regulatory governance standards

C) Run daily phishing simulations for the security team within established organizational risk appetite thresholds

D) Integrate automated deprovisioning with HR status changes so account disabling is triggered when employment ends.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Create the account with standard default access only, and add finance access after a formal authorized request is approved.

Onboarding procedures require verified authorization and role-based, least-privilege provisioning. A verbal request is not sufficient for sensitive access. The service desk should create only the approved default account, then require a formal request and approval before granting finance access. Shared accounts and sending credentials to personal email violate security policy.

Question 2: Option A — Disable the account and revoke active sessions and tokens.

The first offboarding priority is to stop access. Disabling the account and revoking active sessions/tokens immediately prevents the former employee from using existing credentials. Deleting data or transferring mailbox before disabling can create risk or destroy evidence. Password reset alone may not terminate already active sessions.

Question 3: Option B — Orphan account

An orphan account is an active account that no longer has a valid owner or business need, often because offboarding was incomplete. It should be reviewed, disabled, and removed according to retention requirements. Service, shared, and privileged accounts have different definitions and controls.

Question 4: Option D — Instruct the user not to interact with the message, preserve the email, and escalate it to the security team.

The phishing response procedure requires containing the report and escalating it to the security team for analysis. The user should not interact with the message, and the original email should be preserved for investigation. Mass forwarding can spread the phishing email, deleting destroys evidence, and resetting a password is only needed if credentials were entered.

Question 5: Option A — Follow the approved identity verification process; if verification fails, do not reset and escalate the request.

Password reset procedures require strong identity verification before changing credentials. Knowledge of a username or manager name is not sufficient. If the caller cannot satisfy verification, the agent must refuse the reset and escalate. Sending credentials to personal email, asking for the old password, or disabling MFA weakens security.

Question 6: Option C — Remotely wipe the laptop and track asset return through the offboarding checklist.

Offboarding includes collecting or remotely wiping company assets. A missing laptop can expose locally stored data, cached credentials, or VPN configurations. Remote wipe and asset tracking directly address that risk. Domain-wide password changes, mailbox deletion, and MFA token disablement do not control the missing endpoint.

Question 7: Option D — Quarantine the message from all mailboxes and block the sender and URL.

Containment aims to stop the threat from spreading or being accessed. Quarantining the message from all mailboxes and blocking the sender/URL prevents further clicks and delivery. Warnings and forwarding are useful later, but they do not contain the malicious email. Mass password resets are not indicated unless credentials were compromised.

Question 8: Option B — Deny the request and provision only the standard marketing role access; require separate justification and approval for any privileged access.

Onboarding must follow least privilege and role-based access control. Domain administrator access is not justified by future projects and should not be granted by default. The administrator should deny the request, provision the standard role, and require a separate approved request for privileged access. Temporary grants, MFA alone, or shared admin credentials do not fix excessive privilege.

Question 9: Option A — Disable the account and revoke active sessions and tokens, then reset credentials.

When an account is suspected compromised, the procedure should contain the incident first. Disabling the account and revoking active sessions/tokens stops the attacker from continuing to use existing access. Credential reset follows containment. Waiting, merely increasing complexity, or deleting mailbox/VPN profile does not promptly terminate unauthorized access.

Question 10: Option D — Integrate automated deprovisioning with HR status changes so account disabling is triggered when employment ends.

Orphan accounts often result from delayed or missed offboarding. Automating deprovisioning based on HR status changes reduces human delay and ensures accounts are disabled when employment ends. Awareness training, password expiration, and phishing simulations do not directly prevent orphan accounts.